

NEXUS — COMPLETE AUDIT & REMEDIATION REPORT

System Verification, RBAC Security, Database Models, C++ Engine & Commerce Correctness

EXECUTIVE STATUS SUMMARY

This document details the comprehensive end-to-end audit, architectural upgrades, bug remediation, security hardening, and test verification completed across the NEXUS Enterprise Management & Intelligence Platform.

- **Platform Remote:** <https://github.com/aaddi1/NEXUS.git> (Active Git Repository)
- **System Architecture:** Node.js REST API (:5000) + Python FastAPI (:8000) + Native C++ Engine + PostgreSQL 15+ (:5432) + PWA Client (:8001)
- **Integration Quality Gate:** 12 / 12 Automated Integration Tests Passing (100% Pass Rate)
- **Super Admin Authority:** Aryan Sharma (aryan@nexus.com / admin123@nexus.com)

1. COMPLETE AUDIT & RESOLVED ERRORS INVENTORY

1.1 Frontend & Script Runtime Crashes Resolved

- **SyntaxError in app.js Fixed:** Removed dangling object literal snippet left over in stock transfer function around line 1850 that was preventing the browser from parsing the entire script file.
- **ReferenceError (NX_PHOTOS) Fixed:** Corrected unhandled reference to renamed photo catalog on line 2520 by creating unified alias safe fallback, preventing runtime crash.
- **Dev Overlay Blocker (#nexus-dev-popup) Removed:** Permanently removed blocking z-index 999999 development notice dialog that intercepted user mouse clicks across the entire screen.
- **Unchecked DOM Manipulations Guarded:** Added safe element verification across all dashboard and table initializer functions, preventing uncaught TypeError exceptions on initial load.

1.2 Security & Authentication Vulnerabilities Remediated

- **Server-Side Role-Based Access Control (RBAC):** Built requireRole, requireSuperAdmin, and requireFounderOrAdmin middlewares. Protected /api/admin behind superadmin checks (returning HTTP 403 Forbidden to unauthorized accounts).
- **Registration Privilege Escalation Blocked:** Public signup endpoint /api/auth/register now strips and normalizes unauthorized role=superadmin or workspace=system attempts to standard Owner defaults.
- **Cryptographic Password Reset Flow Implemented:** Built /api/auth/forgot-password and /api/auth/reset-password endpoints utilizing 32-byte cryptographic hex tokens with 1-hour expiration and bcrypt hashing.
- **Brute-Force Attack Mitigation:** Added sliding-window rate limiting middleware across authentication routes.

NEXUS — SYSTEM ARCHITECTURE & COMMERCE

HARDENING

2. COMMERCE LOGIC & DATABASE INTEGRITY HARDENING

2.1 Stock Overselling Prevention via Row-Level Mutexes

Previously, order placement silently clamped negative stock using `GREATEST(0, quantity - requested)`. The transaction engine has been rebuilt with strict ACID concurrency protection:

- **PostgreSQL Row Lock:** Every product SKU requested locks the exact warehouse stock row via `SELECT quantity FROM inventory WHERE product_id = $1 AND warehouse = $2 FOR UPDATE`.
- **Strict Rejection:** If available stock is less than the requested amount, the transaction rolls back immediately and returns HTTP 400 Insufficient Stock with detailed quantity diagnostics.

2.2 Permanent Inventory Movements Audit Ledger (`inventory_movements`)

Created a persistent movement ledger table tracking every single inventory increment or decrement across all warehouses:

- **Ledger Fields:** `product_id`, `warehouse`, `quantity_change`, `movement_type` (sale, transfer_in, transfer_out, adjustment, restock), `reference_type`, `reference_id`, `actor_id`, and `created_at`.
- **PostgreSQL Query Parameter Fix:** Resolved critical SQL typing issue by passing signed integer parameters directly via JS parameter bindings rather than inline operator tokens.

2.3 Financial Intelligence, COGS & Payments Synchronization

- **Cost of Goods Sold (COGS):** Added `unit_cost` to products and `order_items` tables so true gross profit and net profit margins can be computed against operating expenses and salaries.
- **Automatic Payment Ledger Reconciliation:** Whenever an order or invoice is settled as paid, a corresponding payment entry is atomically created/updated in the payments table.

3. FOUNDER/ADMIN VS. EMPLOYEE WORKSPACE SEPARATION

Implemented strict role separation ensuring confidential business financial records are never exposed to regular employees:

- **Founder / Super Admin Portal:** Executive Dashboard, Multi-Warehouse Stock Transfers, Workforce Management, Salary Disbursements, Operating Expenses, CRM Deals Pipeline, Analytics, and Super Tech Settings.
- **Employee Personal Workspace:** Scoped strictly to personal assignments: My Sales (attributed orders), My Items (issued demonstration stock), My Salary (payment history & salary invoices), My Issues (support tickets), and My Profile.

NEXUS — NATIVE C++ ENGINE, PWA & TEST REPORT

Clang/CMake Compilation, Automated Quality Gates & Seeded Credentials

4. NATIVE C++ HIGH-PERFORMANCE COMPUTATIONAL ENGINE

Built and compiled a native C++ backend computational engine in cpp/ (built with CMake and Clang++ 17):

- **Pricing Engine (cpp/src/pricing_engine.cpp):** Multi-tiered GST tax computation (CGST, SGST, IGST), dual-mode discounts (Fixed INR vs. Percentage), and live currency conversion.
- **Inventory Optimizer (cpp/src/inventory_optimizer.cpp):** Economic Order Quantity (EOQ) formula, safety stock buffer estimation, and multi-depot stock transfer validation.
- **Crypto Engine (cpp/src/crypto_engine.cpp):** Constant-time HMAC-SHA256 vector invoice checksum verification.
- **Executable Benchmark (cpp/src/main.cpp):** Standalone binary nexus_cpp_engine validating all algorithmic mathematical models.

5. AUTOMATED TEST SUITE & QUALITY GATE VERIFICATION

The integration test suite in backend/tests/api.test.js (invoked via npm test) executes 12 critical verification gates:

- ' Backend Health Check (/api/health) — PASS
- ' Super Admin Authentication (aryan@nexus.com) — PASS
- ' Employee Authentication (riya@nexus.com) — PASS
- ' Registration Role Escalation Prevention (role=superadmin blocked) — PASS
- ' RBAC: Employee cannot access /api/admin/stats (HTTP 403) — PASS
- ' RBAC: Super Admin can access /api/admin/stats (HTTP 200) — PASS
- ' Password Reset Request (/api/auth/forgot-password) — PASS
- ' Commerce: Create Order with Atomic Stock Decrement — PASS
- ' Commerce: Reject Order when Stock is Insufficient (HTTP 400) — PASS
- ' Employee Workspace: Scoped Personal Stats & Sales (/api/employees/me/workspace) — PASS
- ' Financial Intelligence Overview (/api/financials/overview) — PASS
- ' Complaints System: Submit Ticket -> Super Admin Resolve — PASS

6. DEFAULT SEEDED CREDENTIALS REFERENCE

- **Super Admin (Aryan Sharma):** aryan@nexus.com / admin123 (or admin123@nexus.com / admin123)
- **Enterprise Company Owner:** reliance@nexus.com / admin123
- **Retail Shop Owner:** shopowner@nexus.com / admin123
- **Sales Lead (Employee):** riya@nexus.com / admin123
- **Inventory Manager (Employee):** rahul@nexus.com / admin123
- **Finance Lead (Employee):** arjun@nexus.com / admin123